

# Table of Contents

## Cisco Secure Workload — UK Cyber Essentials **Plus**

### Technical Runbook | UK Organisations & Government Supply Chain

**Version:** 1.0

**Scheme reference:** NCSC Cyber Essentials (requirements for IT infrastructure — align artefacts to your certification body's current scheme document)

**Use Case:** Fresh install, hybrid environment (on-prem + cloud)

**Certification track:** **Cyber Essentials Plus** (includes **hands-on technical verification** by an assessor — not self-assessment alone)

---

## Reader's Guide

**Who this is for.** UK organisations pursuing or maintaining **Cyber Essentials Plus**, especially those bidding for **UK government contracts** where the scheme is mandated or strongly expected. Security and infrastructure teams preparing for **external assessment**, internal IT preparing **evidence packs**, and programme managers who need a **technical narrative** that goes beyond the scheme's minimum paperwork.

### Questions this runbook helps you answer:

- For the **Firewalls** control, can I show **deny-by-default** enforcement and **documented boundaries** between internal zones—not only perimeter appliances? (CE1)
- For **Secure configuration**, can I prove what software is installed, detect **configuration drift**, and spot **unnecessary services** still listening? (CE2)
- For **User access control**, can I tie **east-west reachability** to **least privilege** and surface **privileged process activity** on sensitive servers? (CE3)
- For **Malware protection**, can I complement AV/EDR with **unseen-process detection**, **forensic rules**, and **lateral-movement containment**? (CE4)
- For **Patch / security update management**, can I prioritise **unpatched CVEs** with **EPSS and reachability**, and maintain a **live software inventory**? (CE5)
- For **Plus**, what **technical artefacts** support the assessor's **on-site / remote verification** and **vulnerability scans**—without replacing the certification body's test plan?

**What you'll need.** Scope of **in-scope devices** per your certification body, change windows for sensor install, a CMDB or cloud asset inventory for reconciliation, patch ticketing, and (for Plus) coordination with your **Cyber Essentials Plus assessor** on test windows.

**Where to start.** Sections 1–2 to align scope; 3–4 for sensor and inventory; 5–6 for baseline visibility; 7–8 for policy design and enforcement; section 9 for **audit / evidence** ahead of assessment; section 10 for **boundaries** so you do not over-claim against the scheme.

---

## CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

| CSW term                              | Meaning                                              | Why compliance teams care                                  |
|---------------------------------------|------------------------------------------------------|------------------------------------------------------------|
| <b>Scope</b>                          | Logical boundary (CDE, PHI zone, CUI enclave)        | Defines the systems you must prove are isolated            |
| <b>Label / filter</b>                 | Tag or query assigning workloads to scopes           | Automates scope membership — reduces drift                 |
| <b>ADM</b>                            | Application Dependency Mapping from observed traffic | <b>Live</b> network/data-flow diagram for assessors        |
| <b>Workspace</b>                      | Policy container for one scope or application        | Where allow/deny rules are authored                        |
| <b>Monitor → Simulation → Enforce</b> | Safe rollout sequence                                | Simulation = change-board evidence before blocking traffic |
| <b>Denied Connections</b>             | Log of flows blocked by policy                       | Primary proof that enforcement <b>operates</b>             |

**Console areas:** Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

**Read next:** [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

---

## Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

| Phase               | Goal                           | Key CSW actions                              | Typical duration |
|---------------------|--------------------------------|----------------------------------------------|------------------|
| <b>1 — Coverage</b> | Every in-scope workload in CSW | Install agents/connectors ; apply compliance | Days 1–10        |

| Phase               | Goal                              | Key CSW actions                                            | Typical duration |
|---------------------|-----------------------------------|------------------------------------------------------------|------------------|
|                     |                                   | labels; create scope                                       |                  |
| <b>2 — Baseline</b> | Machine-generated flow map        | Run ADM $\geq 2$ weeks; export clusters; app-owner signoff | Days 11–28       |
| <b>3 — Policy</b>   | Designed isolation before enforce | Build workspace; Simulation mode; fix false positives      | Days 29–45       |
| <b>4 — Operate</b>  | Continuous proof between audits   | Enforce; quarterly export pack; ADM refresh every 90 days  | Ongoing          |

### Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

### Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle ( $\geq 2$  weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

### Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run  $\geq 1$  week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

### Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denials, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

### What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW

addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

---

## CSW effectiveness for this framework

- CE1 workload-level firewall enforcement proof
- CE2 secure configuration baseline from agent inventory
- CE5 patch management evidence scoped to workloads

**Compared to manual programmes:** static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

## 1. Overview

**Cyber Essentials** is a **UK government–endorsed** baseline certification. It does not replace ISO 27001, NIS2, or deep red-teaming—but it is often **contractually required** for public-sector supply chain work. **Cyber Essentials Plus** adds **independent technical verification** (including **penetration-style testing** and hands-on checks by an assessor) on top of the **Cyber Essentials** self-assessment questionnaire. CSW is **not** a certification body; it **produces technical evidence and controls** that often **exceed** the scheme minimum, demonstrating **security maturity** to auditors, customers, and internal risk committees.

### Scheme structure vs. CSW (five technical themes)

The NCSC scheme organises requirements into **five technical control areas**. This runbook labels them **CE1–CE5** for cross-reference to implementation plans. Your assessor’s materials may order or word them slightly differently—map row-for-row to their checklist.

| Cyber Essentials theme                         | CSW role                                                                                                                                               | Evidence focus                                                                                                |
|------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>CE1 — Firewalls &amp; Internet gateways</b> | <b>Direct (workload firewall)</b> — host-based <b>microsegmentation</b> enforces <b>deny-by-default</b> between zones; complements perimeter firewalls | Allow/deny rule exports, simulation vs enforcement reports, boundary diagrams backed by <b>observed</b> flows |
| <b>CE2 — Secure configuration</b>              | <b>Direct (visibility + drift)</b> — <b>software inventory</b> (packages/versions); <b>baseline / drift</b> detection; <b>process &amp;</b>            | Inventory exports, drift alerts, listener reports                                                             |

| Cyber Essentials theme                  | CSW role                                                                                                                                                                                                                                                                 | Evidence focus                                                          |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| <b>CE3 — User access control</b>        | <b>listener</b> visibility for unnecessary services<br><b>Supporting</b> → <b>strong with identity integration</b> — <b>identity-aware segmentation</b> restricts which users/processes can reach which workloads; <b>process context</b> surfaces <b>privileged</b> use | Policy tied to identity labels; ADM with user context where available   |
| <b>CE4 — Malware protection</b>         | <b>Complementary</b> — CSW does <b>not</b> replace <b>anti-malware</b> ; <b>process monitoring</b> detects <b>anomalous / unseen</b> binaries; <b>forensic rules</b> flag suspicious patterns; <b>microsegmentation</b> limits <b>lateral movement</b>                   | Process anomaly alerts, forensic timeline exports, containment evidence |
| <b>CE5 — Security update management</b> | <b>Direct (prioritisation + inventory)</b> — <b>CVE awareness</b> and <b>EPSS</b> ; <b>software inventory</b> tracks patch levels; <b>reachability analysis</b> prioritises exposed unpatched workloads                                                                  | Vulnerability + reachability reports, risk-ranked backlogs              |

### Cyber Essentials vs. Cyber Essentials Plus (assessment model)

| Aspect           | Cyber Essentials (basic)                           | Cyber Essentials Plus                                                                                   |
|------------------|----------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Assessment style | <b>Self-assessment questionnaire</b> + declaration | <b>Hands-on technical verification</b> by accredited assessor                                           |
| Testing          | Organiser attests controls                         | <b>Internal/external technical checks</b> , malware delivery tests, etc. (per assessor plan)            |
| CSW's role       | Evidence preparation for answers                   | <b>Live enforcement and telemetry</b> during assessor activity; <b>pre/post</b> flow and policy exports |

## 2. Pre-Deployment Checklist

Before deploying CSW sensors on **in-scope** systems:

- ☐ CSW cluster (SaaS or on-prem) is provisioned and reachable from workloads (**HTTPS 443** outbound typical)
  - ☐ **In-scope asset list** agreed with certification body (servers, laptops, firewalls—per scheme version)
  - ☐ Linux/Windows sensor compatibility verified for all **Plus candidate** workloads
  - ☐ Cloud accounts connected (**AWS, Azure, GCP**) via CSW cloud connectors where applicable
  - ☐ Stakeholders: IT operations, security, **assessment lead**, change management
  - ☐ **Monitoring-only** phase approved before enforcement (recommended)
  - ☐ Baseline change-freeze or tagging convention agreed (e.g. `compliance:cyber-essentials-plus`)
- 

## 3. Phase 1 — Sensor deployment (Days 1–5)

### 3.1 On-premises workloads

**Install software sensors:**

```
# Linux (RHEL/CentOS/Rocky/Alma)
sudo rpm -ivh tet-sensor-<version>.rpm
```

```
# Debian / Ubuntu
sudo dpkg -i tet-sensor-<version>.deb
```

```
# Verify agent service (name may vary slightly by package); example:
sudo systemctl status tet-sensor
# or
sudo systemctl status csw-agent
```

**Windows:** install the MSI supplied for your CSW release; confirm the service is **Running** and reporting to the correct cluster URL.

**Initial posture (recommended):**

- Enforcement: **Monitoring only** until baselines exist
- Enable **process hash**, **network flow**, and **vulnerability** telemetry where licensed
- Apply tags: `env:production`, `compliance:cyber-essentials-plus`, `ce-scope:in`

### 3.2 Cloud workloads

**Option A — Sensor on every in-scope VM:** same as on-prem.

## Option B — Cloud connectors (agentless breadth):

CSW UI → Platform → External Orchestrators

- Add AWS / Azure / GCP connector
- Least-privilege IAM / service principal
- Enable flow-related ingestion per connector documentation

### 3.3 Sensor validation

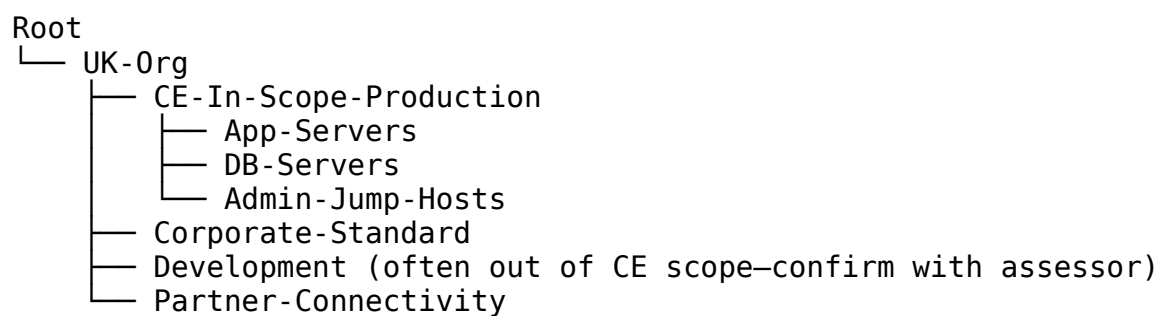
CSW UI → Manage → Agents

- Status: Active for all in-scope hosts
  - Version alignment across cluster
  - Confirm telemetry indicators (flows / inventory updating)
- 

## 4. Phase 2 — Scope & inventory design (Days 6–10)

### 4.1 Scope architecture (UK enterprise pattern)

Design scopes around **trust zones** and **data sensitivity**—mirroring how you describe **firewall zones** to an assessor:



### 4.2 Auto-discovery filters (examples)

Filter: DB-Listeners

- Process: mysql, postgres, sqlservr, oracle
- Ports: 3306, 5432, 1433, 1521

Filter: High-Risk-Services

- Ports: 22, 3389, 445, 135, 5985

### 4.3 Labelling strategy

| Label key | Example         | Purpose                             |
|-----------|-----------------|-------------------------------------|
| ce-scope  | in, out         | In-scope for certification boundary |
| env       | production, dev | Separates test systems              |
| tier      | web, app, data  | Segmentation policy grouping        |
| owner     | team name       | Accountability                      |

## 5. Phase 3 — Visibility & baseline (Days 11–25)

### 5.1 Application Dependency Mapping (ADM)

ADM builds the **observed network map** assessors expect you to understand—useful for **CE1** (boundaries) and **CE5** (what is reachable from where).

CSW UI → Investigate → Application Dependency Mapping  
→ New workspace: "UK-CE-Plus-ADM"  
→ Scope: CE-In-Scope-Production  
→ Window: 2–4 weeks (include payroll / month-end if applicable)  
→ Enable process context (and user context if sensors support)

### 5.2 Baseline and secure configuration (CE2)

| Activity              | CSW capability                | Assessor-relevant output        |
|-----------------------|-------------------------------|---------------------------------|
| Software inventory    | Installed packages / versions | Export per workload             |
| Drift from gold image | Baseline deviation detection  | Drift incidents with timestamps |
| Unnecessary services  | Listening processes           | Listener report by scope        |

Document **who approves** baseline changes in your change tool—CSW surfaces *what* changed; **policy** records *who authorised* it.

### 5.3 Patch posture visibility (CE5)

CSW UI → Investigate → Vulnerabilities (or Vulnerability Report – per release)  
→ Scope: CE-In-Scope-Production  
→ Sort by CVSS / exploit intel / EPSS where available  
→ Add reachability context (exposed to untrusted networks?)

---

## 6. Phase 4 — Policy design (Days 26–40)

Translate **Cyber Essentials** intent into **CSW segmentation** workspaces. **Perimeter firewalls** remain in scope for CE1; CSW proves **workload-level** enforcement **inside** the boundary.

### 6.1 Policy themes (conceptual)

**Deny-by-default matrix (CE1 / lateral containment):**

DENY: Any → DB-Tier (default deny inbound)  
DENY: App-Tier → Internet (except approved proxy / patch endpoints)  
DENY: Corporate-Standard → CE-In-Scope-Production (except jump host paths)

### Allowlists (least privilege — CE3 alignment):

ALLOW: App-Servers → DB-Servers (tcp/1433 or tcp/5432 – prefer TLS/native encryption per app)  
ALLOW: Admin-Jump-Hosts → App-Servers (tcp/22, tcp/3389)  
ALLOW: CE-In-Scope-Production → Approved-Patch-Mirrors (tcp/443)

### Plaintext and risky protocol detection (pairs with CE2/CE4 narratives):

ALERT or DENY: sensitive scopes using cleartext where TLS is mandated (e.g. HTTP to admin interfaces, legacy SMB patterns – tune to your standard)

## 6.2 Policy workspace setup

CSW UI → Defend → Segmentation  
→ New workspace: "UK-CE-Plus-Enforcement"  
→ Scope: CE-In-Scope-Production  
→ Import ADM-suggested policies → reconcile with intended architecture  
→ Phase: Simulation → Enforcement (staged)

---

## 7. Phase 5 — Enforcement (Days 41–60+)

### 7.1 Recommended progression

| Stage | Mode | Duration | Purpose | |---|---|---| | A | Simulation | 2–3 weeks | Tune rules before assessor visit | | B | Enforce **obvious** deny rules | 1 week | Close high-risk paths | | C | Full enforcement | Ongoing | Production baseline for Plus |

### 7.2 During Plus technical verification

- Maintain a **read-only** export of **active policies** dated the assessment window
  - Capture **assessor IP ranges** only if your assessor instructs you to allow test traffic—**do not** weaken production security without written agreement
  - Run **flow search** filtered to **test interval** to narrate any blocked or allowed tester activity
- 

## 8. Phase 6 — Monitoring, alerting & audit evidence

### 8.1 Alert catalogue (examples)

| Alert                          | CSW signal      | CE mapping |
|--------------------------------|-----------------|------------|
| New listener on sensitive tier | Listener delta  | CE2        |
| Deny hit on production policy  | Enforcement log | CE1 / CE3  |
| Unseen process hash            | Process anomaly | CE4        |

| Alert                                     | CSW signal          | CE mapping |
|-------------------------------------------|---------------------|------------|
| Critical CVE on internet-exposed workload | Vuln + reachability | CE5        |
| East-west path to DB from new source      | Flow novelty        | CE1 / CE3  |

## 8.2 Evidence for certification and annual refresh

| Evidence item                             | CSW source                    | Typical CE mapping       |
|-------------------------------------------|-------------------------------|--------------------------|
| Segmentation / firewall rule set          | Policy workspace export       | CE1                      |
| Inventory of software & versions          | Inventory export              | CE2 / CE5                |
| Baseline drift report                     | Drift / configuration modules | CE2                      |
| Vulnerability backlog with prioritisation | Vuln report + EPSS / exposure | CE5                      |
| Flow logs with process attribution        | Flow search export            | CE1–CE5 (investigations) |
| Incident reconstruction bundle            | Process + flow timeline       | CE4 / IR                 |

Retain evidence per your **legal / records** policy; Cyber Essentials does not specify log retention as HIPAA does—align to **NCSC / internal** standards.

## 9. Control-by-control mapping (requirement → capability → evidence)

Use this table as the **crosswalk** for your **evidence register**. Wording of official requirements must track your assessor's **current** scheme document.

| UK CE theme                     | Representative scheme intent (summary)                                 | CSW capability                                                                               | Evidence produced                                                                 |
|---------------------------------|------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| <b>CE1 Firewalls</b>            | Boundary protection; <b>default deny</b> ; controlled inbound/outbound | Host-based <b>microsegmentation</b> ; zone-to-zone <b>deny-by-default</b> ; ADM-backed rules | Policy export; simulation vs enforcement report; ADM diagram; deny-hit statistics |
| <b>CE2 Secure configuration</b> | Harden systems; remove/disable unnecessary                             | <b>Software inventory</b> ; <b>baseline drift</b> ;                                          | Inventory CSV; drift incidents; listener reports                                  |

| UK CE theme                    | Representative scheme intent (summary)                  | CSW capability                                                                                                              | Evidence produced                                                             |
|--------------------------------|---------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
|                                | software & services                                     | <b>process/listener</b> visibility                                                                                          |                                                                               |
| <b>CE3 User access control</b> | Least privilege accounts; controlled admin access       | <b>Identity-aware</b> policies (where integrated); constrained <b>east-west</b> paths; <b>privileged process</b> visibility | Identity-scoped rules; ADM with user context; process reports for admin tools |
| <b>CE4 Malware protection</b>  | Anti-malware / appropriate alternative controls         | <b>Complement AV</b> : unseen binary detection; <b>forensic detection</b> rules; <b>segmentation</b> limiting spread        | Alert history; process tree exports; blocked lateral paths                    |
| <b>CE5 Security updates</b>    | Patch <b>high/critical</b> issues in defined timeframes | <b>CVE</b> inventory; <b>EPSS</b> prioritisation; <b>reachability</b> scoring; correlation to inventory                     | Risk-ranked CVE report; “exposed unpatched” dashboard export                  |

## 10. Boundaries — what CSW does **not** cover

- **Certification decision** — only your **accredited Cyber Essentials/Cyber Essentials Plus** assessor certifies compliance.
- **Questionnaire completion** — administrative attestation remains your responsibility.
- **Perimeter appliance configuration** — CSW does not replace **corporate firewalls**, WAFs, or router ACLs; it **complements** them with **host enforcement**.
- **Anti-malware product** — CSW is **not** a replacement for **supported AV/EDR** required by CE4; it adds **behavioural** and **network containment** evidence.
- **MFA, IAM, and account lifecycle** — CE3 requires **organisational** IAM processes; CSW enforces **network** reachability consistent with those decisions.
- **Patch deployment** — CSW **identifies** and **prioritises**; **WSUS, SCCM, patch orchestration** tools perform installation.
- **Physical security and supplier contracts** — outside product scope.

## 11. Audit preparation & evidence export (worked examples)

### 11.1 CLI / API patterns (illustrative)

Many teams export via UI; automate where possible:

```
# Example: periodic inventory pull via your CSW automation (replace
with official API/CLI for your version)
# curl -s -H "Authorization: Bearer ${CSW_API_TOKEN}" \
#   "${CSW_API_BASE}/v1/inventory/workloads?scope=CE-In-Scope-
Production" \
#   -o "evidence/inventory-$(date +%F).json"
```

Store exports in an **immutable** evidence bucket (WORM / object lock) if your GRC team requires it.

### 11.2 SIEM forwarding (optional)

Forward **flow** / **enforcement** / **alert** metadata to Splunk / Sentinel / Chronicle to correlate with **firewall** and **EDR** logs for **Plus** interviews.

---

## Related frameworks

- [NIS2 \(EU 2022/2555\)](#) — for UK organisations with EU entities; different legal base, overlapping technical measures.
  - [NIST SP 800-53](#) — deeper control catalogue if Cyber Essentials is a **stepping stone** to FedRAMP-style rigour.
  - [CIS Controls v8](#) — operational mapping sibling for **inventory, vuln, segmentation**.
- 

## Appendix A — Conceptual policy fragment (YAML-style)

```
workspace: UK-CE-Plus-Enforcement
scope: CE-In-Scope-Production
mode: simulation # promote to enforcement after sign-off
rules:
  - id: CE1-default-deny-to-db
    action: deny
    source_scope: any
    destination_scope: DB-Servers
    services: [tcp/1433, tcp/3306, tcp/5432]
    notes: "Allow only explicit app tiers via companion allow rules."

  - id: CE5-allow-patch-egress
    action: allow
    source_scope: CE-In-Scope-Production
    destination_fqdn_list: [wsus.corp.example, patches.vendor.example]
    services: [tcp/443]
```

## Appendix B — Evidence pack checklist (Cyber Essentials Plus window)

| Artefact                                      | Suggested frequency | Owner                 |
|-----------------------------------------------|---------------------|-----------------------|
| Active segmentation policy export             | Assessment week     | Security engineering  |
| ADM workspace snapshot                        | Quarterly           | Security architecture |
| Vulnerability report (in-scope)               | Monthly minimum     | Vuln management       |
| Drift / baseline exceptions                   | Per change ticket   | IT operations         |
| Incident example (redacted) using flow export | If available        | IR lead               |

*Prepared for Cisco customer engagements. Map control text to your assessor's current NCSC scheme document; scheme versions evolve.*